

ICS 35.020

CCS L70

YD

中华人民共和国通信行业标准

YD/T ××××—××××

隐私计算 可信执行环境产品安全要求

Privacy preserving computation security requirements of trusted execution
environment products

（报批稿）

2023 年 7 月 31 日

××××-××-××发布

××××-××-××实施

中华人民共和国工业和信息化部 发布

目 次

前 言II

1 范围.....1

2 规范性引用文件.....1

3 术语和定义.....1

4 缩略语.....2

5 技术架构.....2

 5.1 计算过程.....2

 5.2 架构体系.....3

6 安全要求.....4

 6.1 计算环境安全.....4

 6.2 计算过程安全.....5

 6.3 数据安全.....5

 6.4 密码安全.....6

 6.5 通信安全.....7

 6.6 平台通用安全.....7

 6.7 稳定性.....7

 6.8 日志与存证.....7

参 考 文 献.....9

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》给出的规定起草。

本文件是隐私计算系列标准之一，该系列标准结构和名称如下：

- 隐私计算 联邦学习产品性能要求和测试方法
- 隐私计算 联邦学习产品安全要求和测试方法
- 隐私计算 可信执行环境产品性能测试要求
- 隐私计算 可信执行环境产品安全要求
- 隐私计算 多方安全计算产品性能要求和测试方法
- 隐私计算 多方安全计算产品安全要求和测试方法

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、蚂蚁科技集团股份有限公司、阿里云计算有限公司、北京火山引擎科技有限公司、北京冲量在线科技有限公司、杭州镭威信息科技有限公司、上海富数科技有限公司、北京百度网讯科技有限公司、腾讯云计算（北京）有限责任公司、深圳市洞见智慧科技有限公司、北京交通大学、杭州趣链科技有限公司、杭州安恒信息技术股份有限公司、北京熠智科技有限公司、极术（杭州）科技有限公司、同盾科技有限公司、中国移动通信集团有限公司、广州广电运通金融电子股份有限公司。

本文件主要起草人：王思源、袁博、白玉真、闫树、贾轩、杨靖世、吕艾临、童锦瑞、宋佳楠、闫守孟、肖俊贤、张晓蒙、张焱山、刘颖男、汪晟、刘敬彬、孙勇、张尧、陈浩栋、刘尧、宋雨筱、唐丹叶、李帜、王爽、杨天雅、周燃、卞阳、周吉文、孙赫、于欢、李克鹏、刘江、姜峰、何浩、王伟、刘吉强、徐静、杜静漪、王吾冰、张振永、张金波、屠家华、黄翠婷、贾金龙、田康、王静、茹志强、冯玲云、李叶东、马利。

隐私计算 可信执行环境产品安全要求

1 范围

本文件规定了基于可信执行环境的隐私计算产品的安全要求，包括计算环境安全、计算过程安全、数据安全、密码安全、通信安全、平台通用安全、稳定性、日志与存证等内容。
本文件适用于基于可信执行环境的隐私计算产品的研发、测试、评估和验收等。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本(包括所有的修改单)适用于本文件。

- GB/T 20518-2018 信息安全技术 公钥基础设施 数字证书格式
- GB/T 25069-2010 信息安全技术 术语
- GB/T 32905-2016 信息安全技术 SM3密码杂凑算法
- GB/T 32907-2016 信息安全技术 SM4分组密码算法
- GB/T 32915-2016 信息安全技术 二元序列随机性检测方式
- GB/T 32918.1-2016 信息安全技术 SM2椭圆曲线公钥密码算法 第1部分:总则
- GB/T 37092-2018 信息安全技术 密码模块安全要求
- ISO/IEC 18031-2011 信息技术 安全技术 随机比特生成 (Information technology. Security techniques. Random bit generation)
- T/CCSA 406-2022 基于可信执行环境的数据计算平台技术要求与测试方法

3 术语和定义

GB/T 25069-2022、T/CCSA 406-2022界定的以及下列术语和定义适用于本文件。

3.1

可信执行环境 **trusted execution environment**

数据计算平台上由软硬件方法构建的一个安全区域，可保证在安全区域内部加载的代码和数据在保密性和完整性方面得到保护。

[来源：T/CCSA 406-2022，3.1]

3.2

远程验证 **remote attestation**

由发起验证端向远程计算端发起，计算端向发起验证端证明该计算端与目标验证环境相比无改动。在可信执行环境中，被证明物包括计算运行环境的安全性以及运行代码的完整性。通常情况下，这个验证模式需要借助一个远程验证服务提供商。

[来源：T/CCSA 406-2022，3.8]

3.3

可信计算基 trusted computing base

计算机信息系统内保护装置的总体，包括硬件、固件、软件等并负责执行安全策略的组合体。

[来源：GB/T 25069-2010，2.2.1.68]

3.4

数字证书 digital certificate

指在互联网通讯中标志通讯各方身份信息的一个数字认证，人们可以在网上用它来识别对方的身份，数字证书又称数字标识。

[来源：GB/T 25069-2022，3.579]

3.5

重放攻击 replay attack

攻击者通过记录通信会话，以便日后某个时刻重放整个或部分会话的主动攻击方式。

[来源：GB/T 25069-2022，3.78]

4 缩略语

下列缩略语适用于本文件。

HMAC：基于哈希的消息验证码（Hash-based Message Authentication Code）

TCB：可信计算基（Trusted Computing Base）

TEE：可信执行环境（Trusted Execution Environment）

5 技术架构

5.1 计算过程

基于可信执行环境的隐私计算产品参与方关系如图1所示，在一次计算任务中，涉及到五类角色的交互，其中一个实体可以同时承担多个角色。

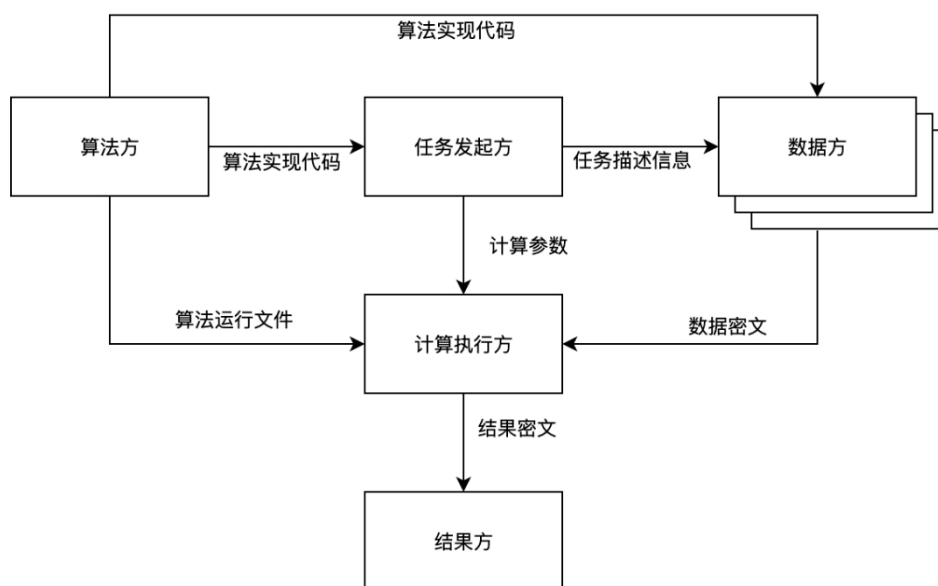


图1 基于可信执行环境的隐私计算产品参与方关系示意图

不同角色承担的职能参考如下描述：

- 任务发起方：任务发起方发起隐私计算任务，任务描述应包含数据需求、算法需求和计算执行需求等。其他各方应获得清晰的需求描述，并达成共识。任务发起方通常也是结果方；
- 算法方：算法方依据算法需求提供需要运行的算法实现代码。数据方可以对算法程序进行核验；
- 数据方：数据方应以密文形式提供任务协商确定的待计算数据。数据方应验证计算执行方对应执行环境的安全性和正确性；
- 计算执行方：计算执行方负责计算的具体执行，算法运行文件应由算法方提供，计算数据应由数据方提供。在实际计算场景中，根据不同需要，一个参与方可担任多个角色，计算执行方、任务发起方和算法方可能会集成在一方。计算应在TEE中执行，应全流程保证数据的隐私性；
- 结果方：结果方获得计算结果密文，解密后得到明文计算结果。

5.2 架构体系

基于可信执行环境的数据计算平台的架构体系包含任务管理服务、算法服务、任务调度与跟踪服务、TEE计算资源，如图2所示，虚线框为平台的非必要组成部分。

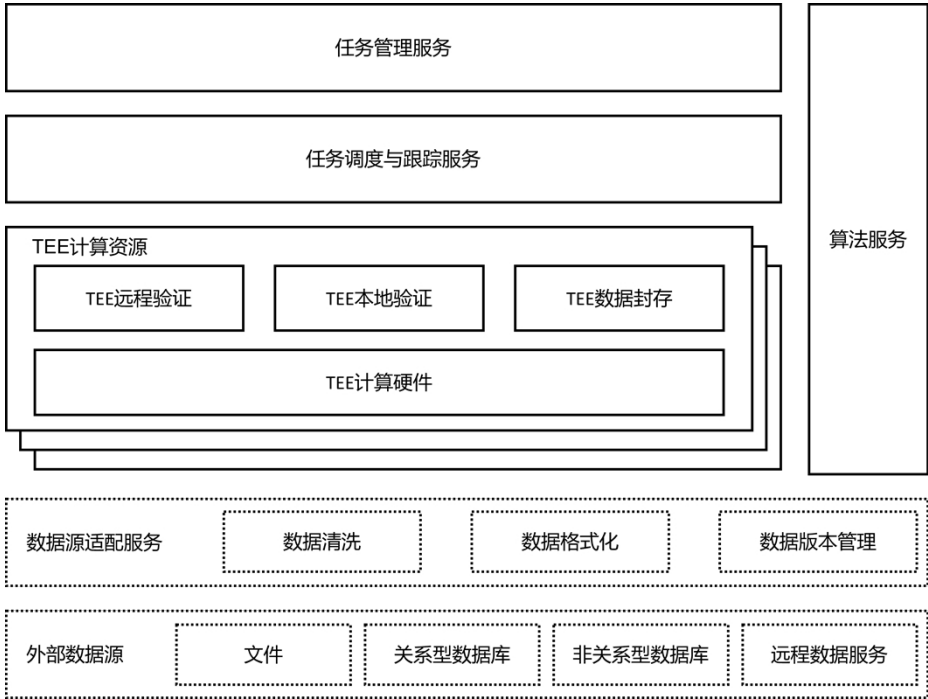


图2 基于可信执行环境的隐私计算产品架构体系示意图

图2中各部分的内涵与功能如下：

- a) 任务管理服务主要面向用户，提供协作计算在平台上管理的功能。包括面向用户的计算任务管理、数据管理、算法管理、TEE节点管理、日志与审计等功能；
- b) 算法服务面向任务发起方和算法方，算法方在算法服务中提交发布可运行在TEE中的算法。任务发起方在算法服务中选取算法，发起协作计算任务；
- c) 任务调度服务应参考算法资源要求、网络性能状态等指标，均衡动态地将计算任务调度到TEE计算节点；任务跟踪服务跟踪TEE计算节点的任务处理状态、任务调度结果，推动任务内各方的有序协同；
- d) TEE计算资源是由一个或多个TEE计算节点构成的计算资源池，每一个TEE计算节点由TEE计算硬件以及在硬件基础上提供的远程验证、TEE数据封存服务构成。分布式TEE计算节点之间由可靠的通信网络连接。

6 安全要求

6.1 计算环境安全

基于可信执行环境的隐私计算产品计算环境安全要求如下：

- a) 应保护TEE关联的TCB范围内代码的完整性，采用如公钥签名的方式检验代码发布者及其来源可信，防止代码被未授权修改。宜支持对授权范围外的恶意修改以及不安全代码版本的检测告警；
- b) 应支持TEE关联的TCB范围内代码的安全更新，包括更新策略配置、最低运行版本要求。宜支持安全版本管理功能，保证产品运行在安全版本，且能够检测到降级不安全版本的行为并提示风险；

- c) 应采用远程验证等手段确保TEE的运行硬件环境合法，运行程序未被篡改。若采用远程验证的方式，应保证协议能够抵抗验证报告的重放攻击，宜包含对计算任务的代码、数据文件等任务关键内容的一致性校验；
- d) 硬件密钥部署和信任体系建立流程应保证安全和透明，宜通过可信第三方作为信任根避免对硬件设备提供商的安全依赖；
- e) 宜支持在不同架构的TEE之间进行远程验证报告校验，实现不同架构TEE之间的安全信道建立，保证互联互通和互操作性。

6.2 计算过程安全

基于可信执行环境的隐私计算产品计算过程安全要求如下：

- a) 应支持对应用算法逻辑安全性的人工审核机制，人工审核结果包含数字签名，存在信任关系。宜采用自动化机制识别应用算法逻辑中可能存在的安全问题；
- b) 数据方在提供数据进行计算之前，应确保实际使用的应用算法与协商的结果一致；
- c) 应支持对输入数据的规范性检测，对识别到的数据规范性问题具备相应的处理操作（如预警报告、任务终止、自动处理等）。宜支持对输入数据的安全性检测，对识别到的恶意输入问题具备相应的处理操作（如预警报告、任务终止等）；
- d) 计算方在执行计算操作之前，应确保各数据方提供的数据与任务协商的结果一致；
- e) 计算方在执行计算操作之前，应确保参与方信息、数据源信息等计算任务信息与任务协商的结果一致，修改计算任务信息会导致计算任务不可执行；
- f) 宜支持基于远程验证报告实现 TEE 签发者的一致性校验，验证算法由指定用户签发；
- g) 应保证可信环境与非可信环境之间的隔离，如采用进程级隔离、体系结构层隔离或虚拟化级隔离。宜支持计算内存的物理加密保护，以抵抗如物理冷冻攻击等安全威胁；
- h) 宜确保计算过程使用的算法代码与产生的计算结果存在映射关系，具备不可抵赖性且支持事后审查；
- i) 宜支持内存地址的随机化处理。若攻击者控制操作系统，仅能观测到 TEE 的起始地址，无法获取具体的 TEE 内存程序内存布局；
- j) 宜支持镜像加密功能。将确定的 TEE 镜像以加密的形式存储在本地或远端服务器，TEE 运行前从服务器获取加密镜像，并在 TEE 内解密、加载，防止镜像被其他用户获取；
- k) TEE 中的加密操作、计算任务宜支持抵抗某些特定的已知侧信道攻击，如 meltdown、spectre 等。

6.3 数据安全

基于可信执行环境的隐私计算产品数据安全要求如下：

- a) 应保证数据方与计算节点之间数据交换发生在安全通道内，传输过程中数据全程保持密态，且仅会在TEE对应的TCB内被解密。输入的数据和输出的结果应包含完整性检验及保护机制；
- b) 应保证任务数据的隔离性，防止攻击者通过重放攻击等形式窃取或篡改任务数据。任务数据包括参与方信息、数据源信息、nonce信息等任务信息和输入数据；
- c) 应保证计算结果的保密性，计算结果是加密处理的，仅结果方可解密；

- d) 应具备验证隐私计算任务请求中数据使用授权的合法性的能力，支持对使用者、使用范围授权和控制。宜支持细粒度的授权和控制，除使用者、使用范围外，包含用法、用量、使用时间、使用次数等维度；
- e) 应保护敏感数据落盘的保密性和完整性。敏感数据应加密存储，并对相应的密钥进行安全管理。应充分考虑落盘数据的容灾措施，通过节点同步、数据备份等方式保障数据盘损坏时，落盘数据及时恢复和应用。宜支持借助TEE数据封存技术提高敏感数据落盘的保密性，限制其只能在明确授权的安全环境下被读取；
- f) 应保证数据在下线或授权到期之后，按照相关参与方制定的销毁策略进行销毁，且过程可审计；
- g) 宜支持封存任务数据，封存的密文数据只能在被明确授权的安全环境下解密。

6.4 密码安全

基于可信执行环境的隐私计算产品的密码技术应满足以下安全要求：

- a) 应保证使用的密码算法在产品生命周期内满足最低安全强度要求。在当前计算资源水平下，应提供大于等于112的计算安全强度，宜提供大于等于128的计算安全强度；
- b) 应保证密码算法使用的正确性，如对称和非对称密码算法加解密结果的正确性、杂凑密码算法产生杂凑值的正确性，IV、Padding设置的正确性等；
- c) 应保证密钥在安全可信的环境中生成，包括用户本地环境、可信的TEE环境等。宜支持使用满足GB/T 37092-2018等标准要求的硬件密码设备生成密钥；
- d) 产品使用的随机数应满足GB/T 32915-2017、ISO/IEC 18031-2011等标准要求的随机性。确定性随机数生成器应采用已有标准规定算法进行实现，如NIST SP800-90Ar1。除特殊业务场景需求外，安全环境中宜使用TEE内置的硬件随机数；
- e) 用户在TEE中设计实现的密钥(除公钥外)在离开安全环境前，应采用TEE内置密钥或采用符合GB/T 37092-2018等标准要求的硬件密码设备生成的密钥进行加密处理；
- f) 密钥(除公钥外)应以密文形式存储或备份或归档在可控的环境中，且无法被非授权的访问、使用、泄露、修改和替换。公钥应存储或备份或归档在可控的环境中，且无法被非授权的修改和替换。宜使用满足GB/T 37092-2018等标准要求的硬件密码设备存储安全密钥，同时确保密钥导入流程的安全性；
- g) 加密密钥、签名密钥等密钥应具有明确、单一的用途，密钥使用过程中应包含相应的安全措施，私钥不应泄露给除生成方之外的其他方，对称密钥不应泄露给通信之外的其他方，密钥应具有明确的更新周期和备份机制，非对称密钥应满足前向安全性；
- h) 密钥在生命周期结束、发生泄露或有泄露风险时应支持密钥销毁。密钥泄露时，应立即停止使用，并启动相应的应急处理措施；
- i) 应保证密钥交换协议的安全性，交换过程涉及的随机数生成、密码算法安全强度、协商生成的密钥强度均应符合上述要求。密钥交换双方应有明确的身份验证以抵抗中间人攻击，交换信息应抵抗重放攻击；
- j) 密钥分发过程应采取身份认证等方式保障密钥的保密性和完整性以及分发者/接收者身份的真实性等。应保障密钥分发过程能够抗截取、假冒、篡改、重放等攻击；
- k) 产品中使用的数字证书应满足标准格式要求，如RFC3280定义的X.509证书等，包括版本号、证书序列号、签名算法标识符、颁发者名称、有效期、主体名称、主体公钥信息等内容。数字证书应在有效期内，证书链宜完整且有效；
- l) 对于系统中使用的对称或非对称加密、密钥协商、签名、杂凑等算法、协议，宜使用满足GB/T 32918.1-2016、GB/T 32905-2016、GB/T 32907-2016等标准规范的密码算法实现。数字证书宜满足GB/T 20518-2018等标准要求。

6.5 通信安全

基于可信执行环境的隐私计算产品通信安全要求如下：

- a) 通信双方应在通道建立之前使用密码技术进行身份认证、密钥交换、信道加密，安全信道建立的过程中宜结合远程验证完成；
- b) 应保护通信过程中重要敏感数据的保密性；
- c) 应保护通信过程中重要数据的完整性，如采用数字签名、HMAC 等技术实现；
- d) 通信过程宜支持抗重放机制，如采用硬件单调递增器、可信时间戳等技术实现；
- e) 数据接收方宜具备对通信数据篡改后的识别和异常处理机制。

6.6 平台通用安全

基于可信执行环境的隐私计算产品平台通用安全要求如下：

- a) 应支持对接入用户的身份认证。用户身份鉴别信息丢失或失效时，应支持采用技术措施确保鉴别信息重置过程的安全；隐藏口令、身份信息 etc 用户敏感认证信息的存储应具备保护措施；
- b) 宜支持用户多因子身份认证，使用两种或两种以上组合认证方式，包括并行独立认证或串行关联认证；
- c) 应支持用户角色、权限的设置以及对应的访问控制；
- d) 应不存在半年内已公布的高危安全漏洞，宜不存在半年内已公布的中危安全漏洞；
- e) 应仅开放隐私计算服务必要的网络端口，且只有鉴权通过后可访问；
- f) 若产品支持在线升级功能，宜支持对升级包的完整性校验，出现异常时应回滚到更新前状态；
- g) 计算节点、调度平台的相关配置信息宜禁止非正常、未授权的修改。

6.7 稳定性

基于可信执行环境的隐私计算产品稳定性要求如下：

- a) 宜支持对节点故障的检测与响应。节点故障时，任务报错（或短时故障不干扰任务正确执行）而非输出错误结果；故障排除后，任务可以重启且正确完成；在发生节点故障到故障排除并正确完成计算任务的整个过程中，均不会泄漏任何一方的数据信息；
- b) 宜支持对网络故障的检测与响应。网络故障时，任务报错（或短时故障不干扰任务正确执行）而非输出错误结果；故障排除后，任务可以重启且正确完成；在发生网络故障到故障排除并正确完成计算任务的整个过程中，均不会泄漏任何一方的数据信息。

6.8 日志与存证

基于可信执行环境的隐私计算产品日志与存证要求如下：

- a) 应对各参与方的数据输入过程、结果输出过程等关键环节进行存证，存证中应包含计算过程产生的相关结果和信息。存证应采用密码技术保证其防篡改要求，且支持根据预设的最少保留时间进行存储；
- b) 用户操作日志应包含各参与方的日常管理、访问控制等记录，包括但不限于对敏感数据操作、数据加解密处理在内的数据全生命周期的正确记录；应支持查询计算任务启动、运行、结束等状态信息；

- c) 日志与存证应提供对异常隐私计算任务的审计能力，应支持快速检索异常计算任务信息，应支持针对错误原因、状态的追溯。

参 考 文 献

[1]NIST SP800-90Ar1 Recommendation for Random Number Generation Using Deterministic Random Bit Generators
